Estudo de caso: Univazada

ADEQUAÇÃO À LGPD

Projeto Integrado Multidisciplinar

Orientador: Dr. Davis Souza Alves

FaCiência e TiExames | 2024

INTEGRANTES

PIM

- Geishe Michelle Silva
- Deyvisson Ferreira
- Janaína Lomando
- José de Melo



DPOasS Ltda

- Janice Lira
- Paulo Emerson
- Rodrigo Silva

RESUMO

Desde a vigência das leis de proteção de dados, como a GDPR e LGPD, para o Brasil, tem se visto uma movimentação das organizações para a adequação, no entanto alguns desafios são encontrados: um deles é entender a dimensão e todos os âmbitos que envolvem a adequação à LGPD e GDPR, outro motivo é a resistência à mudança cultural, além da restrição orçamentária que pode ser um fator impeditivo. Este trabalho trará a adequação da Universidade Univazada com essas dificuldades e ainda um recente incidente de vazamentos de dados.

INDICE

- Introdução
- Problema
- Revisão da Literatura
- Metodologia
- Análise dos Resultados
- Considerações Finais
- Referências
- Agradecimento

INTRODUÇÃO

- As Tecnologias de Informação e Comunicação (TICs) têm transformado áreas como educação, comércio e atendimento médico, mas também aumentaram os riscos de ataques cibernéticos.
- Garantir a disponibilidade, integridade, confidencialidade e autenticidade da informação é crucial para a segurança na era digital.
- A Lei Geral de Proteção de Dados Pessoais (LGPD) e o Regulamento Geral de Proteção de Dados (GDPR) foram implementados para regulamentar o uso e proteger os dados pessoais.
- O estudo de caso propõe identificar os processos de tratamento de dados, definir bases legais adequadas, identificar riscos e impactos, e estabelecer um programa de governança em privacidade.
- O estudo destaca como objeto de trabalho as normas internacionais como ISO/IEC 27001, 27002, 27005 e 27701 para nos direcionar enquanto segurança da informação e a adequação de privacidade.
- A conformidade com a LGPD não só protege dados pessoais, mas também fortalece a credibilidade e a confiança da instituição junto aos titulares de dados.



INTRODUÇÃO

(Pinheiro, 2020)

Por ser uma regulamentação híbrida, a LGPD exige conhecimento multidisciplinares, tanto técnicos, relacionados à governança de dados e de segurança da informação, quanto jurídicos, para definir as prioridades, realizar a atualização documental e apoiar na resposta a incidentes.

(Alves, Davis e Lima, Adrianne, 2021)

A análise de riscos é a chave na implementação das leis de proteção e privacidade de dados nos meios eletrônicos ou físicos. Deve-se analisar o potencial de que ameaças possam explorar vulnerabilidades de um ativo de informação ou grupo de ativos de informação, causando assim dano para a organização.

PROBLEMA

Como realizar a adequação à LGPD da Universidade Univazada, considerando recente vazamento de dados, além de uma cultura resistente às novas políticas de segurança e privacidade e restrições orçamentárias?

1º Problema

Incidente de Segurança da informação com vazamentos de dados comprometeu dados de alunos, docentes e funcionários, conforme Art. 48 da LGPD o Controlador deve informar a ANPD e ao Titular, caso acarrete risco ou dano abrangente aos Titulares.

2º Problema

Resistência à implementação de novas políticas de segurança e privacidade, preocupados com a burocracia e limitações ao acesso de dados para pesquisa. Além da restrição orçamentária.

REVISÃO DA LITERATURA

- A Lei Geral de Proteção de Dados Pessoais (LGPD) revolucionou o tratamento de dados no Brasil, impactando profundamente o setor educacional. Instituições de ensino devem aderir a princípios como finalidade, necessidade, adequação, transparência e segurança no manejo de dados pessoais. Além de garantir conformidade legal e evitar sanções, a proteção de direitos como acesso, retificação e apagamento de dados fortalece a confiança da comunidade escolar. A implementação dessas medidas não só protege os dados, mas também promove uma relação transparente e segura com alunos, pais, professores e funcionários, consolidando a integridade e a credibilidade da instituição.

- O Regulamento Geral de Proteção de Dados (GDPR) 2016/679, instituído pela União Europeia em 2016 e em vigor desde maio de 2018, influenciou a criação da Lei Geral de Proteção de Dados Pessoais (LGPD) no Brasil. Essas legislações têm objetivos comuns que visam proteger dados pessoais, mas o GDPR apresenta disposições mais abrangentes, aplicáveis globalmente, e garante maior controle aos titulares sobre seus dados. Princípios como legalidade, transparência, minimização e segurança são comuns a ambos, mas o GDPR inclui requisitos mais rigorosos de accountability e proteção contra decisões automatizadas. Enquanto o GDPR serve como referência global, a LGPD representa um avanço significativo no Brasil, embora com espaço para melhorias que a alinhem mais estreitamente ao GDPR.

REVISÃO DA LITERATURA

- A conformidade com a LGPD e o GDPR requer ajustes nas práticas de dados das instituições de ensino, com foco em segurança e consentimento rigorosos. Isso envolve designar responsáveis específicos e investir em tecnologia para melhorar a gestão de dados, fortalecendo assim a confiança e criando um ambiente educacional seguro e ético. A implementação da LGPD no setor educacional demanda proteção dos dados pessoais dos alunos e funcionários, garantindo transparência, segurança e conformidade legal em todas as etapas do processo, desde a coleta até a exclusão. Alinhada ao GDPR da União Europeia, essa legislação visa preservar a privacidade dos indivíduos, moldando as práticas educacionais em direção a uma maior proteção e responsabilidade no tratamento de dados.

- A proteção de dados nas universidades no Brasil envolve a aplicação de várias leis, além da LGPD, como a Constituição Federal, a LDB, o ECA, o Marco Civil da Internet, a Lei de Acesso à Informação, a Lei de Propriedade Intelectual, o Código Civil e o Código de Defesa do Consumidor. Essas leis formam um sólido arcabouço jurídico que exige das instituições de ensino medidas de segurança e transparência no tratamento de dados pessoais. Portarias do Ministério da Educação e o SINAES reforçam essas diretrizes, destacando a importância de um compromisso ético e estratégico com a proteção de dados para fortalecer a confiança e a excelência no setor educacional.

METODOLOGIA

Teoria e Conceitos.

A abordagem descritiva nos permite retratar com fidelidade a realidade da adequação à LGPD, mapeando as práticas e experiências das empresas. Já a natureza exploratória nos guia na descoberta de novos insights e perspectivas, ampliando a compreensão do tema. A metodologia qualitativa, por sua vez, nos permite aprofundar na análise dos dados coletados, revelando nuances e significados que os números sozinhos não podem captar.

METODOLOGIA

M.1

Revisão Bibliográfica: alicerçando a pesquisa em fontes sólida, mergulhamos em um extenso universo de leis, regulamentos e normas ISO relacionados à proteção de dados, buscando embasar a pesquisa em bases sólidas e atualizadas.

Foi realizado uma pesquisa documental rigorosa, consultando fontes confiáveis e reconhecidas na área.

- Consulta em livros, artigos científicos, periódicos e outros materiais publicados sobre os temas da LGPD, GDPR, proteção de dados e metodologias de pesquisa qualitativa. Essa pesquisa foi realizada em bases de dados online, como Google Scholar, SciELO, Periódicos CAPES dentre outros.

METODOLOGIA

M.2

Pesquisa Exploratória em sites : Buscamos a compreensão de Políticas de Privacidade na Prática, analisamos com lupa as políticas de privacidade de empresas e organizações de diversos setores, buscando identificar as melhores práticas e desafios na adequação à LGPD e GDPR. Por meio de um estudo aprofundado dos textos das políticas, buscando compreender seus objetivos, alcance e efetividade.

- Modelo ROPA, RIPD: Elaboração de um modelo robusto para categorizar os dados coletados, facilitando a análise e a comparação entre diferentes empresas.
- Documentos Diversos: Análise de documentos relevantes para o processo de adequação, como guias, manuais e relatórios, complementando a pesquisa.

METODOLOGIA

Revisão Sistemática: Mapeamento do Conhecimento Científico com Precisão

M.3

1. Navegamos nas diversas bases de dados como Scopus, referência global em pesquisa científica, em busca de artigos relevantes sobre a LGPD.

2. Utilização de expressão como "Privacy and data protection and governance" para direcionar a pesquisa com mais precisão.

3. Análise: Elaboração de quadros detalhados para categorizar e analisar os resultados da busca, extraindo insights valiosos.

ESTUDO DE CASO

- Conforme o contexto foi apresentado pela Univazada um incidente de vazamento de dados, onde já existia um relatório de Pentest, que informava as vulnerabilidades existentes, dentre essas destacou-se o ransomware sem a custódia e sem a criptografia dos dados, onde o Pentester sugeriu algumas melhorias.

- O relatório de sugestões do Pentester, foram encontradas falhas de segurança física e segurança lógica, ensejando diversas melhorias para a arquitetura, desenvolvimento de sistemas, segurança de banco de dados e infraestrutura utilizada pela Univazada.

- A proposta comercial sugere os passos necessários para constituição da equipe em parceria, modificação de cultura, adequação dos dispositivos físicos e modificação lógica para o atendimento às necessidades da adequação da privacidade e proteção de dados.

ANÁLISE E RESULTADOS



Dentro da estrutura do Relatório de Pentest, associado com a análise desenvolvida pelas equipes multidisciplinares com avaliação do ROPA e do RIPD, foram utilizadas como objeto do trabalho algumas ISO da ABNT: ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 27005, ISO/IEC 27701, ISO/IEC 29134, ISO/IEC 31000, ISO/IEC 38500

CRONOGRAMA

1º mês	2º e 3º mês	4º mês	5º a 12º mês
Identificação			
	Análise		
		Planejamento e Entrega	
			Melhoria Contínua e Acompanhamento

ANÁLISE E RESULTADOS – FASES

Identificação

Nossa equipe de especialistas identificará os sistemas, setores e indivíduos envolvidos no tratamento de dados pessoais, bem como suas respectivas obrigações de privacidade e proteção de dados conforme estabelecido pela LGPD.

Análise

Imersão nas operações para concluir o Mapeamento de Fluxo de Dados e a Análise de Riscos. Criação do Inventário de Dados e Relatório de Riscos à Privacidade.

Planejamento e Entrega

Criação de documentos obrigatórios; Desenvolvimento de Procedimentos de Resposta à Solicitação de Usuário/ANPD e de Resposta à Incidentes de Segurança da Informação.

Melhoria Contínua

Estabelecer o Programa de Governança

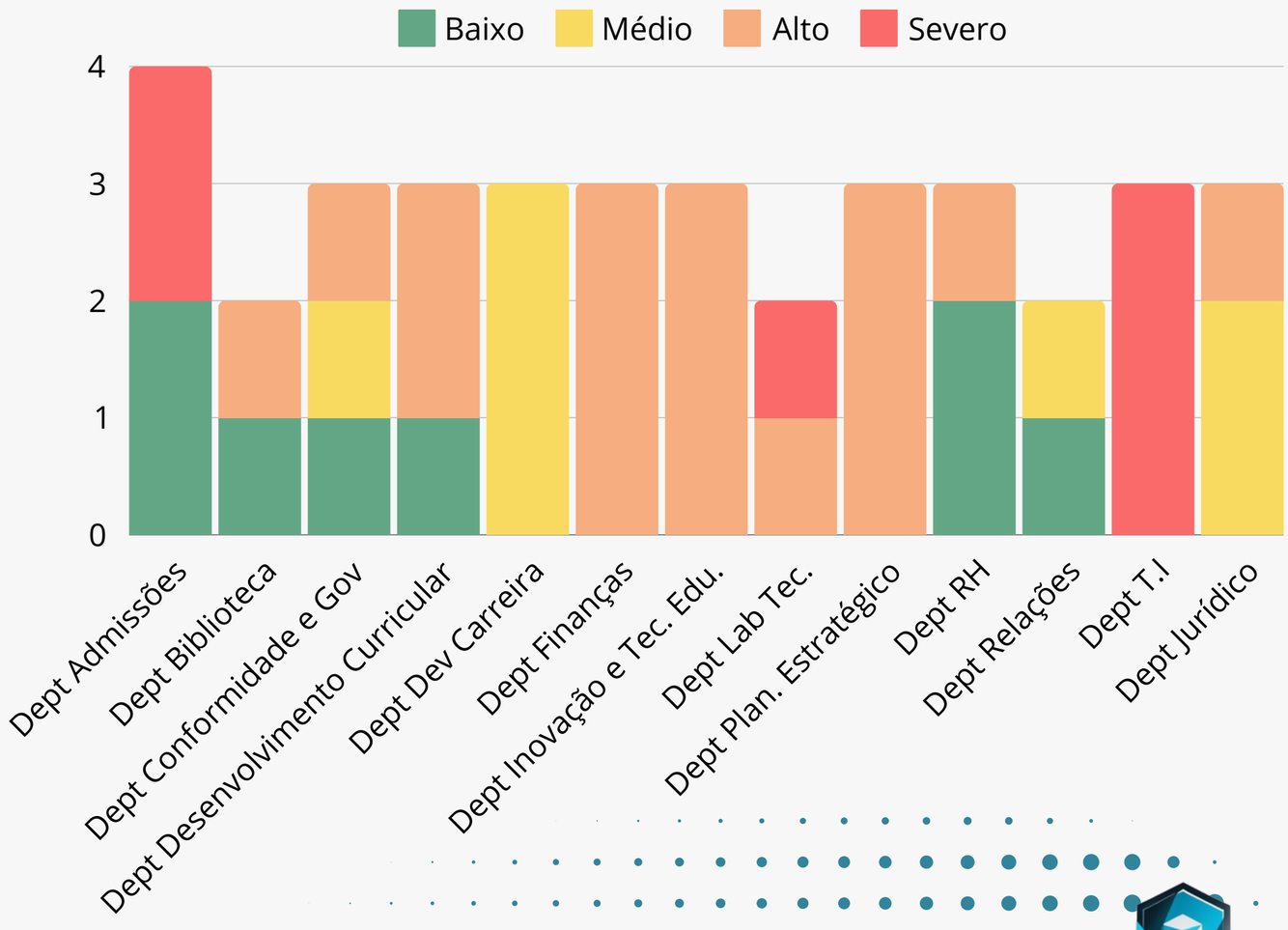
ANÁLISE E RESULTADOS

ROPA (Art. 37 - LGPD)

Registro da Operações de Proteção de Dados

ANÁLISE E RESULTADOS

Foram analisados os processos internos da Univazada através do registro de operações e tratamento de dados (RoPA art. 37 da LGPD). Dos documentos disponibilizados, foram identificados 13 departamentos, entre estratégicos, táticos e operacionais, e mapeados 38 processos que tratam dados de titulares, classificando os riscos associados ao tratamento (RIPD art. 38 da LGPD).



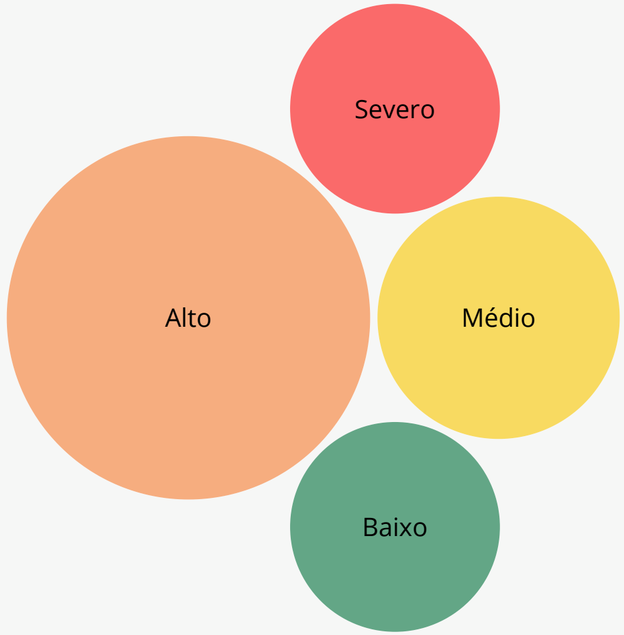
ANÁLISE E RESULTADOS

Riscos identificados

Acesso não autorizado ; alteração de dados ; impactos psicológicos as titulares; vazamento de dados; uso indevido dos dados; perda ou destruição dos dados; discriminação; assédio e bullying

Medidas para mitigação dos riscos, art. 46 da LGPD

Controle de acesso individualizado; Múltiplo fator de autenticação; Tecnologia de Firewall ; Solução de prevenção de intrusão; Proteção antimalware; Treinamento de sensibilização em privacidade e em segurança da informação; Revisão e melhoria contínua em políticas e procedimentos



ANÁLISE E RESULTADOS

Compartilhamento de dados identificados, art. 27 da LGPD.

- DECRETO-LEI Nº 5.452;
- Lei nº 10.861/2004 (SINAES) - Sistema Nacional de Avaliação da Educação Superior;
- Resoluções do Conselho Nacional de Educação (CNE);
- Lei de Diretrizes e Bases da Educação Nacional (LDB) - Lei nº 9.394/1996 - Portaria Normativa MEC nº 40/2007 (Republicada em 2010);
- Lei - Lei 13.146 - Lei Brasileira de Inclusão da Pessoa com deficiência (art. 30) / Portaria MEC nº 2.678/2002 (Braille)



ANÁLISE E RESULTADOS

Nomeação do DPO

De acordo com art. 41 da LGPD, todo controlador deve nomear o Encarregado de Dados. Neste sentido a Univazada contrata a PIM DPOasS Ltda para o projeto de adequação.

Medidas Técnicas e Administrativas

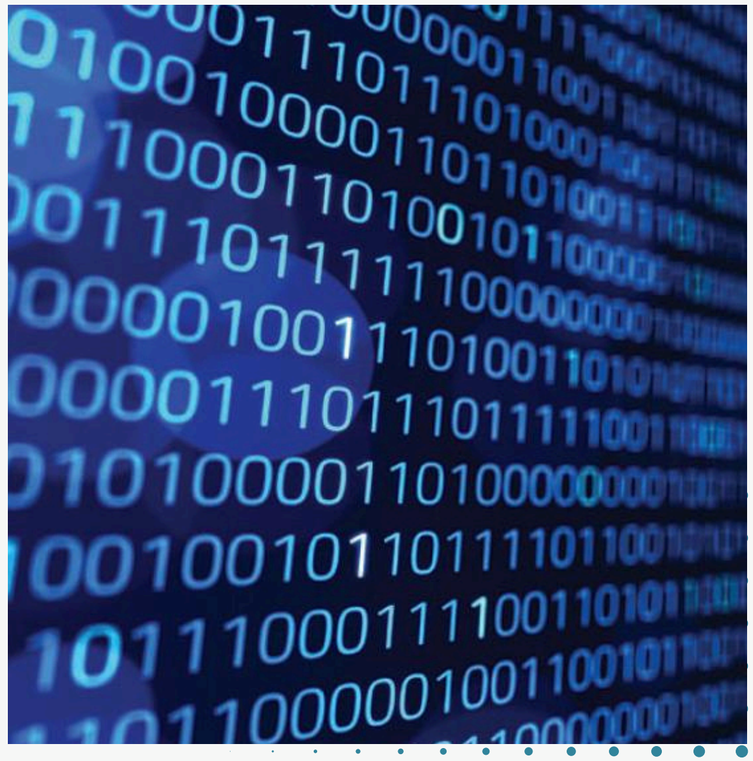
Foram disponibilizadas algumas políticas para garantir a conformidade e documentar as medidas adotadas pela Universidade.

Toda documentação criada para universidade, visa garantir que todas as partes envolvidas compreendam as suas responsabilidades para que o todo esteja em conformidade para mitigação de riscos e garantia da segurança da privacidade dos dados tratados.

CONSIDERAÇÕES FINAIS

Limitações da Pesquisa

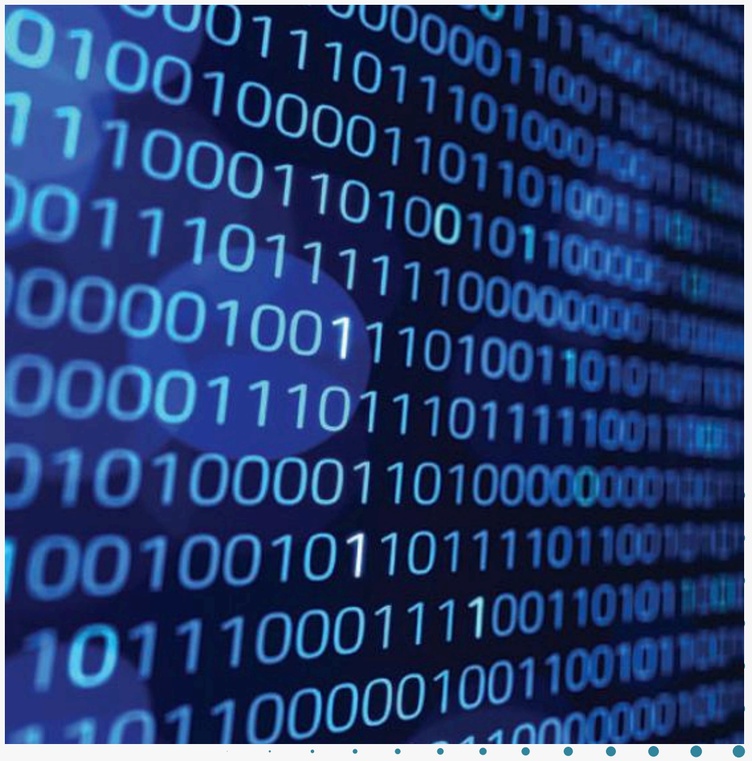
- Restrições orçamentárias
  - Tecnologia e Segurança
  - Treinamento
  - Serviços DPO
- Resistência Interna à Mudança
  - Cultura Organizacional
  - Burocracia
  - Impacto na Pesquisa Acadêmica



CONSIDERAÇÕES FINAIS

Abordagem para superação

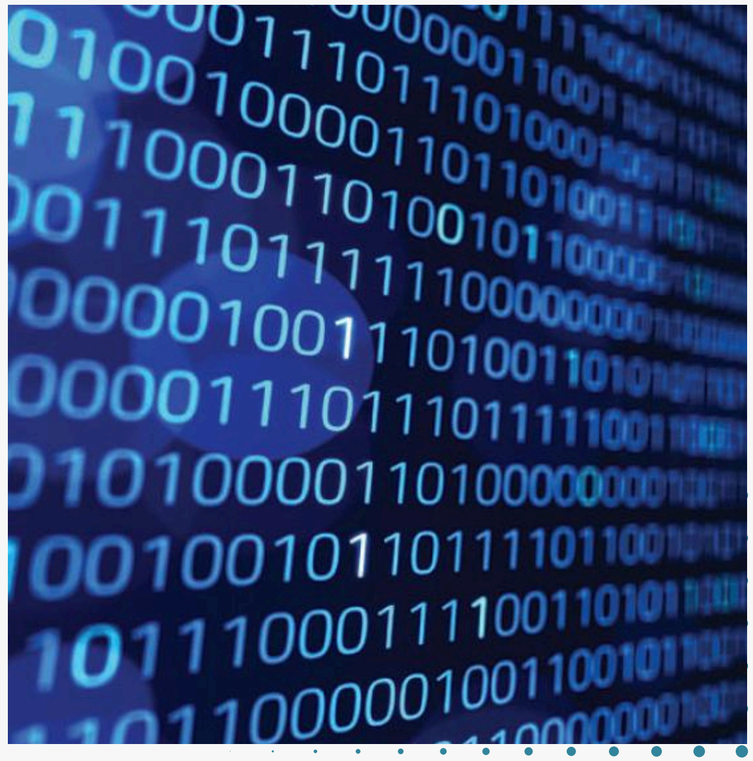
- Priorização Financeira
- Engajamento e Educação
- Comunicação Clara
- Flexibilidade



CONSIDERAÇÕES FINAIS

Contribuições da Pesquisa

- Vazamento de Dados:
  - causas,
  - consequências e
  - medidas
- Implicações Legais e Financeiras
- Importância da adequação (LGPD/GDPR)
- Plano de Ação: SGPI com melhoria contínua



FaCiência e TiExames | 2024

OBRIGADO(A)!

REFERÊNCIAS

- Alves, Davis Souza; Lima, Adrianne - Encarregados: Data Protection Officer (DPO) - Haikai Editora - 2021 - acesso em 19/04/2024
- Pinheiro, Patrícia Peck - Qual o impacto da LGPD em instituições de ensino e pesquisa - RNP - 27/05/2020 - https://www.rnp.br/noticias/qual-o-impacto-da-lgpd-em-instituicoes-de-ensino-e-pesquisa - acesso em 19/04/2024
- BRASIL,2018 - LGPD Nº13.709 - Lei Geral de Proteção de Dados - https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- European Parliament and of the Council, 2016 - GDPR - General Data Protection Regulation - https://gdprinfo.eu/pt-pt/pt-pt-article-1
- Prodanov, Cleber Cristiano, De Freitas, Ernani Cesar. Metodologia do trabalho científico [recurso eletrônico] : métodos e técnicas da pesquisa e do trabalho acadêmico . – 2. ed. – Novo Hamburgo: Universidade Feevale, 2013.